

FinAccrual ERP Platform

Environment and Configuration Setup

Environment variables, OAuth apps, ports and deployment settings

Item	Detail
Project	FinAccrual ERP Platform (Backend API, Excel Add-in, Admin Dashboard)
Document	Environment and Configuration Setup

This document lists every configuration value used by the Backend API, the Excel Add-in and the Admin Dashboard, and explains how to set them for development and production.

1. Configuration Overview

Component	Folder	Configured through	Default port
Backend API (Node.js / Express 5)	Backend/Backend	.env file + src/core/config/index.js	8000
Excel Add-in (React 19, Webpack)	Frontend-React	API_BASE build variable, manifest.xml, manifest.prod.xml	3001 (HTTPS)
Admin Dashboard (React 19, Vite)	Admin	vite.config.ts proxy (URLs also written in source files)	5173
Reverse proxy (optional)	project root	docker-compose.yml, nginx.conf	8085

2. Backend Configuration

2.1 How the .env file is loaded

src/core/config/index.js loads .env using dotenv from several locations, in this order: the backend root, src/, src/core/, the current working directory, then the default lookup. Because dotenv never overwrites a variable that is already set, the **first** file found wins, and real operating-system environment variables always win over the file.

Create the file by copying the template:

```
cd Backend/Backend
cp .env.example .env
```

2.2 Environment variables

Application

Variable	Required	Default	Description
PORT	No	8000	HTTP port of this instance
NODE_ENV	Yes (prod)	—	development or production. Production turns on rate limits,

			secure cookies and disables dev HTTPS
INSTANCE_ID	No	server-1	Label returned by /api/health; use a different value per instance
JWT_SECRET	Yes	jwt-finaccural-secret-key-123	Signing key for application JWTs. Must be a long random value in production
SESSION_SECRET	See note	hard-coded	Listed in .env.example, but the code currently uses a fixed string (see 2.4)
LOG_LEVEL	No	info (prod) / debug	Log level of the pino logger in src/config/logger.js
TRIAL_DURATION_MS	No	120000 (2 min)	Free-trial length in milliseconds. Example: 1209600000 = 14 days
TRIAL_DEFAULT_PLAN	No	trial	Plan name assigned when a trial starts

Database

Variable	Required	Default	Description
DB_HOST	Yes	localhost	MySQL host
DB_PORT	No	3306	MySQL port
DB_NAME	Yes	quickbooks_xero	Database name (example file uses finaccural)
DB_USER	Yes	root	MySQL user
DB_PASSWORD	Yes	123456	MySQL password
DB_SYNC_ALTER	No	false	true = alter tables to match models at start-up

QuickBooks Online

Variable	Required	Example	Description
----------	----------	---------	-------------

QB_CLIENT_ID	Yes	—	Client ID from the Intuit developer app
QB_CLIENT_SECRET	Yes	—	Client secret from the Intuit developer app
QB_REDIRECT_URI	Yes	http://localhost:8000/api/quickbooks/callback	Must match a redirect URI registered in the Intuit app exactly
QB_ENVIRONMENT	No	sandbox	Present in .env.example but not read by the code; the API base URL is fixed to the sandbox in core/constants/index.js

Xero

Variable	Required	Example / Default	Description
XERO_CLIENT_ID	Yes	—	Client ID from the Xero developer app
XERO_CLIENT_SECRET	Yes	—	Client secret
XERO_REDIRECT_URI	Yes	http://localhost:8000/api/xero/callback	Must match the redirect URI registered in Xero
XERO_SCOPES	No	openid profile email offline_access	Space-separated

		accounting.contacts accounting.settings.read	scopes requested at connect time
--	--	---	---

Google sign-in

Variable	Required	Example / Default	Description
GOOGLE_CLIENT_ID	Yes	<id>.apps.googleusercontent.com	OAuth 2.0 client ID
GOOGLE_CLIENT_SECRET	Yes	—	OAuth 2.0 client secret
GOOGLE_REDIRECT_URI	Yes	http://localhost:8000/api/auth/google/callback	Code default is https://localhost:8000/api/auth/google/callback . The alias /api/google/callback also exists

Microsoft sign-in (Entra ID)

Variable	Required	Example / Default	Description
MICROSOFT_CLIENT_ID	Yes	—	Application (client) ID
MICROSOFT_CLIENT_SECRET	Yes	—	Client secret value
MICROSOFT_REDIRECT_URI	Yes	http://localhost:8000/api/microsoft/callback	Also available at /api/auth/microsoft/callback
MICROSOFT_TENANT_ID	No	consumers	Tenant GUID, or common, organizations, consumers
MICROSOFT_SCOPES	No	openid profile email User.Read offline_access	Scopes requested at sign-in

Set automatically (do not set manually)

Variable	Set by	Meaning
BACKEND_HTTPS	src/server.js	true in production, or in development when dev certificates are found; controls the session cookie secure flag

2.3 Sample .env for local development

PORT=8000

NODE_ENV=development

INSTANCE_ID=server-1

JWT_SECRET=change-me-to-a-long-random-string

SESSION_SECRET=change-me-too

DB_HOST=localhost

DB_PORT=3306

DB_NAME=finaccrual

DB_USER=finaccrual

```
DB_PASSWORD=your_database_password

# DB_SYNC_ALTER=false

QB_CLIENT_ID=your_quickbooks_client_id

QB_CLIENT_SECRET=your_quickbooks_client_secret

QB_REDIRECT_URI=http://localhost:8000/api/quickbooks/callback

QB_ENVIRONMENT=sandbox

XERO_CLIENT_ID=your_xero_client_id

XERO_CLIENT_SECRET=your_xero_client_secret

XERO_REDIRECT_URI=http://localhost:8000/api/xero/callback

XERO_SCOPES=openid profile email offline_access accounting.contacts accounting.settings.read

GOOGLE_CLIENT_ID=your_google_client_id.apps.googleusercontent.com

GOOGLE_CLIENT_SECRET=your_google_client_secret

GOOGLE_REDIRECT_URI=http://localhost:8000/api/auth/google/callback

MICROSOFT_CLIENT_ID=your_microsoft_client_id

MICROSOFT_CLIENT_SECRET=your_microsoft_client_secret

MICROSOFT_REDIRECT_URI=http://localhost:8000/api/microsoft/callback

MICROSOFT_TENANT_ID=consumers

LOG_LEVEL=info

# TRIAL_DURATION_MS=1209600000
```

2.4 Values that are hard-coded in the source

Value	Location	Recommendation
Session secret finaccural-node-secret	core/config/index.js	Read process.env.SESSION_SECRET instead so the .env value takes effect
JWT fall-back secret	core/config/index.js	Fail start-up in production if JWT_SECRET is missing
QuickBooks API base	core/constants/index.js	Choose sandbox / production

URL (sandbox)		URL from QB_ENVIRONMENT
Access token lifetime 1 hour, refresh token 7 days	jwt.service.js, auth.service.js	Move to configuration if different lifetimes are needed
Body size limit 15 MB	app.js	Needed for base64 Excel uploads to /api/excel-validation

3. OAuth Application Registration

Each external provider must have an application registered with the **exact** redirect URI used by the backend. A mismatch produces errors such as `redirect_uri_mismatch`.

Provider	Portal	Redirect URI to register (local)	Notes
QuickBooks Online	developer.intuit.com	http://localhost:8000/api/quickbooks/callback	Scope: com.intuit.quickbooks.accounting. Sandbox company required for testing
Xero	developer.xero.com	http://localhost:8000/api/xero/callback	Scopes as in XERO_SCOPES; offline_access is needed for refresh tokens
Google	console.cloud.google.com	http://localhost:8000/api/auth/google/callback	OAuth client type: Web application. Scopes: openid, email, profile
Microsoft	portal.azure.com (Entra ID)	http://localhost:8000/api/microsoft/callback	Add a client secret. Choose account types to match MICROSOFT_TENANT_ID

For production, register the HTTPS URLs of the deployed API (for example <https://api.finaccrual.com/api/quickbooks/callback>) and update the matching `*_REDIRECT_URI` values.

4. Excel Add-in Configuration (Frontend-React)

4.1 API address

The add-in decides which backend to call in `src/taskpane/api.js`, using this order of precedence:

1. `process.env.API_BASE`, injected by Webpack at build time.
2. `window.__FINACCRUAL_CONFIG__.API_BASE`, a runtime override.
3. Fallback <http://localhost:8000>.

In `webpack.config.js` the build-time value is `API_BASE` from the environment if set; otherwise an empty string in production builds (same origin) and <http://localhost:8000> (Windows) or <https://localhost:8000> (macOS) in development.

Production build pointing to the deployed API (PowerShell)

`$env:API_BASE="https://api.finaccrual.com"; npm run build`

macOS / Linux

`API_BASE=https://api.finaccrual.com npm run build`

4.2 Manifests

File	Use	Key settings
manifest.xml	Development / sideloading	Source https://localhost:3001/taskpane.html ; AppDomains include localhost:8000, localhost:8085, Intuit, Xero, Google
manifest.prod.xml	Production deployment	Source https://addin.finaccrual.com/taskpane.html ; AppDomains include https://api.finaccrual.com and https://addin.finaccrual.com

Every domain that the task pane or its pop-ups navigate to must appear in `<AppDomains>`. Replace the sample provider name Contoso and the support/help

URLs with real values before publishing.

4.3 Local browser storage keys

The add-in keeps session state in localStorage (keys such as fa_jwt_token, fa_user_email, fa_user_name, fa_subscription_plan, fa_trial_ends_at, fa_erp_type, fa_current_company_id). These are not server settings but are useful when debugging a sign-in problem.

5. Admin Dashboard Configuration

- ☐ vite.config.ts proxies /api to <http://localhost:8000> during npm run dev.
- ☐ Several source files call <http://localhost:8000> directly (for example modules/auth/Login.tsx and components/layout/Sidebar.tsx). Change these, or introduce a VITE_API_BASE variable, before deploying to another host.
- ☐ The dashboard stores token and user in localStorage after login.

6. HTTPS, Ports and Reverse Proxy

6.1 Development HTTPS

- ☐ The task pane is served over HTTPS at <https://localhost:3001> using certificates from office-addin-dev-certs (stored in ~/.office-addin-dev-certs).
- ☐ **macOS:** Safari/WKWebView blocks HTTPS pages from calling an HTTP API, so server.js automatically starts the backend on HTTPS when those certificates exist. Register HTTPS redirect URIs accordingly.
- ☐ **Windows:** Edge WebView2 allows <http://localhost>, so the backend stays on plain HTTP.
- ☐ **Production:** TLS is expected to be terminated by a reverse proxy or load balancer in front of Node; the app trusts one proxy hop (trust proxy = 1).

6.2 Two-instance setup with Nginx

docker-compose.yml starts an Nginx container (erp_nginx) listening on **8085**. nginx.conf load-balances to two backend instances running on the host at ports **8000** and **8001** through host.docker.internal.

Script (Backend/Backend)	Effect
npm run dev:1	Starts instance server-1 on port 8000
npm run dev:2	Starts instance server-2 on port 8001
npm run dev:all	Runs both instances together

Important OAuth "state" values and pending Xero selections are kept in the in-memory express-session store of one instance, and token-refresh locks are also per-process. With plain round-robin balancing, a callback can reach a different instance from the one that started the flow and fail with "Session expired". Use sticky sessions (for example ip_hash in the Nginx upstream) or a shared session store such as Redis/MySQL before relying on multiple instances.

7. Security-Related Settings in Code

Setting	Value	File
Helmet security headers	Enabled; contentSecurityPolicy and crossOriginOpenerPolicy turned off for the OAuth pop-ups	app.js
CORS	origin: true, credentials allowed; methods GET, POST, PUT, PATCH, DELETE, OPTIONS	app.js
Session cookie	24 h lifetime; secure when BACKEND_HTTPS=true	app.js
JSON body limit	15 MB	app.js
General rate limit	Production: 300 requests / minute / IP (health, ERP and payment routes skipped). Non-production: effectively off	rateLimiters.js
Auth rate limit	Production: 20 requests / 15 min / IP on login, signup, refresh. Off in development	rateLimiters.js
OAuth rate limit	Production: 50 requests / 15 min / IP on ERP connect and callback. Off in development	rateLimiters.js

Input sanitising	Trims strings, strips control characters, <code><script></code> blocks and inline <code>on*=</code> attributes from body and params	sanitize.js
Content-Type check	POST / PUT / PATCH with a body must send <code>application/json</code>	validateHeaders.js

8. Production Checklist

- ☐ Set `NODE_ENV=production`.
- ☐ Set a long random `JWT_SECRET` (at least 32 characters) and fix the session secret so it is read from `SESSION_SECRET`.
- ☐ Use a dedicated MySQL user with a strong password; never use `root` and `123456`.
- ☐ Keep `DB_SYNC_ALTER=false`.
- ☐ Serve the API and the add-in over HTTPS and register the HTTPS redirect URIs with Intuit, Xero, Google and Microsoft.
- ☐ Switch QuickBooks to production keys and production API URL when going live.
- ☐ Build the add-in with `API_BASE` set to the public API URL and publish `manifest.prod.xml`.
- ☐ Set `TRIAL_DURATION_MS` to a real trial length (the default is 2 minutes).
- ☐ Restrict CORS to the add-in and admin origins instead of `origin: true`.
- ☐ Never commit `.env`; only `.env.example` belongs in source control (already enforced by `.gitignore`).
- ☐ Use sticky sessions or a shared session store if running more than one backend instance.